

THREAT ADVISORY



**VULNERABILITY
REPORT**

**Critical Vulnerabilities in Multiple Atlassian Products
being exploited-in-wild**

Date of Publication

July 22, 2022

Admiralty Code

A1

TA Number

TA2022154

Summary

Atlassian has released patches to address a critical security flaw, being tracked as CVE-2022-26138 involving the usage of hard-coded credentials in the Questions For Confluence app for Confluence Server and Confluence Data Center. Additionally, CVE-2022-26136 has been assigned to an authentication bypass and cross-site scripting (XSS) vulnerabilities and CVE-2022-26137 has been assigned to a Cross-origin resource sharing (CORS) bypass vulnerability. Both CVEs impact multiple Atlassian products.

⚙️ CVE Table

CVE	NAME	PATCH
CVE-2022-26138	Hard-Coded Password Confluence Server and Data Center	✓
CVE-2022-26136	Arbitrary Servlet Filter Bypass	✓
CVE-2022-26137	Additional Servlet Filter Invocation	✓

🕸️ Potential MITRE ATT&CK TTPs

TA0042 Resource Development	TA0001 Initial Access	TA0002 Execution	T1588 Obtain Capabilities
T1588.006 Obtain Capabilities: Vulnerabilities	T1190 Exploit Public-Facing Application	T1586 Compromise Accounts	TA0006 Credential Access
T1210 Exploitation of Remote Services	TA0008 Lateral Movement	T1556 Modify Authentication Process	

Technical Details

#1

When a user enables the Questions for Confluence app on Confluence Server, it generates a Confluence user account with the username 'disabledsystemuser' with a hardcoded password. This account is designed to help administrators migrate data from the app to Confluence Cloud and assigned to the confluence-users group, which by default permits viewing and editing of all non-restricted pages in Confluence. An attacker can log into Confluence and access any pages the confluence-users group has access to if the hardcoded password is known. This critical vulnerability has been assigned CVE-2022-26138.

#2

Multiple Servlet Filter vulnerabilities tracked by CVE-2022-26136 and CVE-2022-26137 that affect multiple products including Bamboo Server and Data Center, Bitbucket Server and Data Center, Confluence Server and Data Center, Crowd Server and Data Center, Fisheye and Crucible, Jira Server and Data Center, and Jira Service Management Server and Data Center have been addressed separately.

#3

An unauthenticated remote attacker using a specially crafted HTTP request can exploit CVE-2022-26136 to bypass authentication checks employed by third-party apps, run arbitrary JavaScript code in a user's browser, or launch a cross-site scripting (XSS) attack. An unauthenticated remote attacker can exploit CVE-2022-26137 to cross-origin resource sharing (CORS) bypass through a Servlet Filter that is used to intercept HTTP requests and do some pre- and post-processing before the requests are sent to a back-end resource or web application.

#4

The user account is not removed by default when uninstalling the Questions for Confluence applications and it needs to be disabled or deleted manually. Upgrading to the fixed version removes the disabledsystemuser user account if it has been created previously.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-26138	Questions For Confluence •=2.7.34: affects 2.7.34 •=2.7.35: affects 2.7.35 •=3.0.2: affects 3.0.2	cpe:2.3:a:questions_for_confluence_app:questions_for_confluence_app:2.7.34:*:*:*:*:* cpe:2.3:a:questions_for_confluence_app:questions_for_confluence_app:2.7.35:*:*:*:*:* cpe:2.3:a:questions_for_confluence_app:questions_for_confluence_app:3.0.2:*:*:*:*:*	CWE- 798
CVE-2022-26136	Atlassian Confluence versions are affected before 7.4.17, from 7.5.0 before 7.13.7, from 7.14.0 before 7.14.3, from 7.15.0 before 7.15.2, from 7.16.0 before 7.16.4, from 7.17.0 before 7.17.4, and version 7.21.0.	cpe:2.3:a:atlassian:jira:*:*:*:*:*:* cpe:2.3:a:atlassian:jira_service_management:*:*:*:*:*:* cpe:2.3:a:atlassian:confluence:*:*:*:*:*:*	CWE-180
CVE-2022-26137	Bamboo Server and Data Center, Bitbucket Server and Data Center, Confluence Server and Data Center, Crowd Server and Data Center, Fisheye and Crucible, Jira Server and Data Center and Jira Service Management Server and Data Center		

Patch Links

<https://confluence.atlassian.com/doc/questions-for-confluence-security-advisory-2022-07-20-1142446709.html>

<https://confluence.atlassian.com/security/multiple-products-security-advisory-cve-2022-26136-cve-2022-26137-1141493031.html>

References

<https://portswigger.net/daily-swig/atlassian-patches-batch-of-critical-vulnerabilities-across-multiple-products>

<https://github.com/alcaparra/CVE-2022-26138>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

July 22, 2022 • 7:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com